

Incident Response Engagement Findings & Detection Report

Mission 02 - Root Compromise & Lateral Risk

CLIENT

NexaCorp

Root-level compromise of bru-app-01 (Brussels DC)

Engagement reference INC-2026-002

Phase 1: forensic log analysis · Phase 2: live SIEM validation

Prepared by

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 27 May 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
DISCLAIMER	3
EXECUTIVE SUMMARY	4
A. Introduction	4
B. Scope	4
C. Engagement summary	5
D. Overview of findings	7
E. Overview of recommendations	8
METHODOLOGY	9
A. Procedure	9
B. Severity Ratings	11
ATTACK TIMELINE	12
INVESTIGATION TECHNICAL SUMMARY	13
11. Extended Tor-based reconnaissance phase	13
12. SSH publickey initial access via stolen private key	15
13. SUID misconfiguration on /usr/bin/find enables root	17
14. Credential dump of /etc/shadow	19
15. Backdoor user it_support created	21
16. Systematic SSH private key harvest	23
17. Cron-based persistence in /etc/cron.d/	25
PHASE 2 - LIVE DETECTION IN WAZUH	27
A. Setup & execution (Caldera emulation)	27
B. Detection coverage per task	28
C. False positive analysis	29
D. Detection improvement proposals	30
E. Phase 2 conclusion	32
RISK MATRIX	33
MITRE ATT&CK MAPPING	34
TOOLS AND STANDARDS	35
A. Tools Used	35
B. Standards and Frameworks Followed	36
GLOSSARY AND ACRONYMS	37

Confidentiality Statement

This report documents **Mission 02** of the BeCode Corp internal cybersecurity training programme. The engagement was conducted against a controlled laboratory environment simulating a root-level compromise of an internal application server at the fictitious organisation *NexaCorp*. The target host was a virtualised Debian 12 system (hostname `bru-app-01`) deployed in the BeCode SOC lab under reference BCC-2026.

No real production system, customer data, or third-party infrastructure was targeted, accessed, or affected by this engagement. All IP addresses, hostnames, and accounts referenced in this report (including the threat-actor Tor exit nodes 185.220.101.0/24 and the `bru-app-01` service account `svc_api`) belong to the BeCode training environment and have no production analogue.

This document is classified as **Internal - Not for distribution** under reference **BCC-2026 | INC-2026-002**. It is intended for the BeCode Corp training coordination team, the assigned mentors, and the auditor. Any redistribution outside this scope requires explicit authorization.

Subject to the above, the auditor retains the right to share this report as part of professional portfolios, certification evidence, and job applications, in line with the BeCode Corp policy on training deliverables.

Disclaimer

The findings and recommendations in this report are based on a specific evidence package covering the `bru-app-01` incident of **16 May 2026**. The package, delivered to the BeCode SOC team on 27 May 2026, includes four Linux log files (`auth.log`, `audit.log`, `syslog`, `cron.log`) plus an initial summary file (`INCIDENT_METADATA.txt`). Phase 2 then validated detection coverage on a live Wazuh deployment against a MITRE Caldera adversary simulation run on 27 May 2026.

The investigation reconstructs the kill chain from initial access (17:43:43 local) through privilege escalation (19:43:01 local) and post-exploitation actions (credential dump, backdoor user creation, SSH key sweep, scheduled-task persistence). The evidence package has notable limitations that bound the depth of certain findings: the `audit.log` covers only a 55-minute window (22:47:02 to 23:41:54), and no file-write trace exists for the cron persistence file. These gaps are documented inline in each affected finding.

This report focuses on findings representative of common SOC L1 / L2 analyst workloads, applying the methodology recommended by **NIST SP 800-61r2** (Computer Security Incident Handling Guide) and the **SANS PICERL** incident response process. The incident is treated as a direct continuation of INC-2026-001 (Liege services server), with the SSH key being the most likely pivot artifact between the two compromises.

Executive Summary

A. Introduction

This document reports on the investigation of **INC-2026-002**, a root-level compromise of bru-app-01, NexaCorp's Brussels internal application server. The incident was flagged by NexaCorp IT operations after anomalous account activity was observed on the host, and the BeCode SOC team was tasked with reconstructing the intrusion, characterising its scope, and providing actionable remediation guidance.

The engagement reproduces a real-world DFIR workflow: ingest an evidence bundle delivered by the client, reconstruct the attack chain from authentication and audit logs, identify privilege-escalation and persistence mechanisms, and validate detection coverage on the live Wazuh deployment. A second phase ran a MITRE Caldera adversary simulation against a clean target to measure how the current detection ruleset performs against the techniques observed in Phase 1.

The investigation is constrained by two upstream facts. First, **INC-2026-002 is the direct continuation of INC-2026-001** (the Liege services-server compromise reported earlier in May): the SSH private key used to access bru-app-01 was almost certainly harvested during the prior engagement. Second, the audit-log window covers only 55 minutes (22:47:02 to 23:41:54 local on 16 May), which means the privilege-escalation moment (19:43:01) and the backdoor-user creation (19:47:07) had to be confirmed through alternate sources (auth.log, INCIDENT_METADATA.txt).

B. Scope

Assessment	Details
Host log forensic investigation + detection coverage validation <i>Evidence delivered 27 May 2026</i> <i>Incident occurred 16 May 2026 (Brussels local time, CEST)</i> <i>Phase 1: offline log analysis</i> <i>Phase 2: live Caldera + Wazuh run</i>	What was investigated: • Target host: bru-app-01 (Debian 12, internal 10.10.10.42, mgmt 192.168.100.199) • Service account: svc_api (uid=1000, runs internal REST API) • Wazuh agent: tgt-blue11 (id 041) • Threat actor (network): 36 distinct Tor exit IPs across 5 /24 blocks (185.220.101.0/24 dominant) • Evidence bundle: auth.log, audit.log, syslog, cron.log, INCIDENT_METADATA.txt • In scope: log forensics, kill-chain reconstruction, Wazuh detection validation, rule tuning proposals • Out of scope: live forensic disk acquisition, malware reverse engineering, threat-actor attribution • Related incident: INC-2026-001 (Liege services server, same threat actor, prior week)

C. Engagement summary

The investigation conclusively reconstructs a **coordinated Linux post-exploitation campaign** against an internal NexaCorp host. The attack unfolds in six distinct phases: a Tor-based reconnaissance diversion (39 failed SSH attempts on enumerated usernames), an initial access through SSH public-key authentication using a key the attacker should not have possessed, a two-hour low-privilege beacon (40 successful logins at 3-minute intervals across rotating Tor exit nodes), a privilege escalation through a misconfigured SUID bit on `/usr/bin/find`, a credential-dump and SSH-key-harvest sweep, and the installation of two persistence mechanisms (a backdoor user `it_support` and a cron file `/etc/cron.d/svc-updater`).

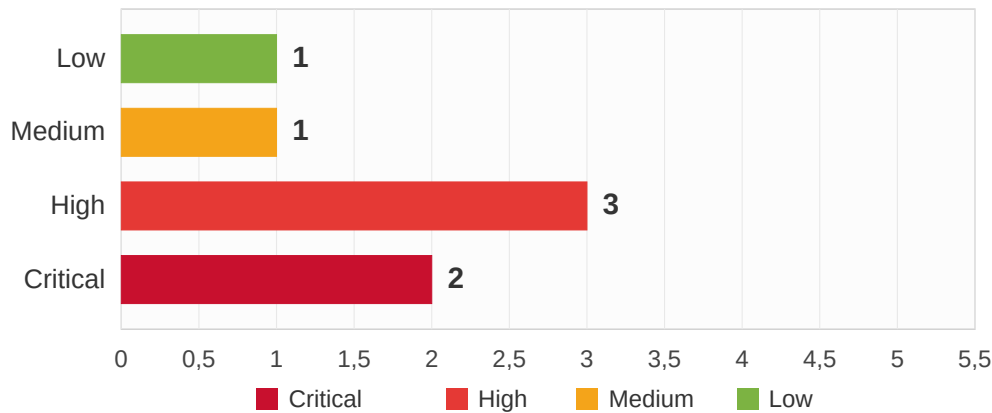
The defining characteristic of this incident is the **linkage with INC-2026-001**. The SSH private key that opened `bru-app-01` was almost certainly harvested during the prior Liege compromise: the same service account `svc_api` is provisioned on both hosts per NexaCorp's standard deployment, the prior incident gave the attacker shell access sufficient to read `/home/svc_api/.ssh/`, and the threat-actor infrastructure (Tor exit blocks, beacon cadence) matches. Treating both incidents as a single coordinated campaign is the correct operational posture.

On the post-exploitation side, the attacker exploited the SUID bit on `find` as a root-read primitive (GTFOBins technique) rather than as an interactive shell escape. Six distinct commands were chained through this mechanism at 60-second intervals: process enumeration (112 events), log search for defender activity (56), health-check (28), sensitive-data probe (27), direct cat `/etc/shadow` (27), and SSH-key sweep across `/home` (54). The pattern is fully automated, with no evidence of interactive operator activity in the captured window.

Phase 2 then ran the MITRE Caldera adversary profile `lab2-linux-privesc` against a clean Wazuh-monitored target. The simulation generated 13 attack-attributable alerts in 5.5 minutes. Two of the four post-exploitation tasks (4A shadow dump and 4B useradd backdoor) are **detected effectively** by existing rules. Task 4C (SSH key harvest) is detected only as a **side effect** of unrelated SUID-enumeration activity. Task 4D (cron persistence) is **not detected at all**, exposing the single most significant detection gap in the current ruleset.

The overall security posture of the affected NexaCorp segment is rated **CRITICAL**. The compromised host gives the attacker three independent re-entry vectors (the original SSH key if not yet rotated, the backdoor user with attacker-defined password, and the cron-based persistence), plus likely lateral exposure to every host whose `authorized_keys` could trust a private key harvested from `bru-app-01`. Until the remediation steps documented in the Investigation Technical Summary are completed, the attacker must be considered to retain potential access.

Vulnerabilities by Severity Level



Two findings reach Critical severity: the SUID misconfiguration on `/usr/bin/find` that gave the attacker root from a low-privilege foothold (I3), and the full credential dump of `/etc/shadow` that puts every account on `bru-app-01` in the attacker's hands (I4). Together they explain the entire post-foothold compromise.

The assessment also identified **three High-severity findings** (I2 the SSH-publickey initial access using a key the attacker should not have possessed, I5 the backdoor user `it_support` with attacker-defined password and `sudo` claim, I7 the cron-based persistence in `/etc/cron.d/` that survives reboots and is currently not detected by Wazuh), **one Medium-severity finding** (I6 the systematic SSH private-key harvest that prepares lateral movement), and **one Low-severity finding** (I1 the Tor-based reconnaissance diversion, low impact in isolation but useful as an attacker-intent signal).

In conclusion, the volume and severity of findings render the affected segment unsuitable for continued operation without comprehensive remediation. Acting on the recommendations presented in this report would neutralise the active persistence mechanisms, close the lateral-movement vector created by the SSH-key harvest, and meaningfully strengthen NexaCorp's detection engineering practice on cron-based persistence techniques.

D. Overview of findings

This list provides the general overview of the seven findings documented in this report. In the reference, the 'I' before the figure stands for *Investigation* (incident response context).

Ref	Description	Severity
I1	Extended Tor-based reconnaissance phase (39 failed SSH attempts, account en	LOW
I2	SSH publickey initial access using a stolen private key, beacon over rotating Tor	HIGH
I3	SUID misconfiguration on /usr/bin/find enables uid=1000 to euid=0 escalation (G	CRITICAL
I4	Credential dump of /etc/shadow (27 direct reads, password hash exfiltration via b	CRITICAL
I5	Backdoor user it_support created with attacker-defined password and sudo rights	HIGH
I6	Systematic SSH private key harvest across /home (54 events), prepares lateral m	MEDIUM
I7	Cron-based persistence installed at /etc/cron.d/svc-updater (per metadata)	HIGH

E. Overview of recommendations

This list is a short overview of the proposed recommendations by finding. Detailed recommendations are provided alongside each finding in the Investigation Technical Summary.

REF	VULNERABILITY	SHORT RECOMMENDATION
I1	Tor-based reconnaissance	Block known Tor exit nodes at the network perimeter for inbound SSH, refreshed hourly from official Tor lists. Lower fail2ban thresholds to surface low-and-slow probing. Add a SIEM correlation rule that aggregates SSH failures by /24 over a 4-hour window.
I2	Stolen SSH key access	P0 - IMMEDIATE. Rotate the compromised SSH key on every NexaCorp host where svc_api is provisioned. Restrict svc_api SSH access to internal source IPs via Match User + AllowUsers. Move to certificate-based SSH (signed by an internal CA with short TTL) to eliminate long-lived static keys.
I3	SUID privilege escalation	Remove the SUID bit on /usr/bin/find immediately (chmod u-s). Audit all SUID binaries on the host against a Debian 12 baseline. Add Wazuh rule 100203 (proposed in Phase 2) to detect uid != 0 && euid == 0 invocations on any binary.
I4	Credential dump	Force password reset for every account on bru-app-01 (chage -d 0). Existing rule 100201 detects /etc/shadow access effectively; ensure tuning excludes daemon noise without suppressing real attack signal.
I5	Backdoor user it_support	Remove the backdoor user (userdel -r it_support). Audit accounts with UIDs >= 1000 created in the last 30 days. Tune Wazuh rule 100202 to require an actual username argument (negate the -D read-only flag) to suppress Wazuh syscollector false positives.
I6	SSH key harvest, lateral exposure	Inventory every host whose authorized_keys could trust a private key from bru-app-01 and treat each as potentially compromised pending verification. Migrate to SSH certificate authority with short-TTL signed credentials to scope the impact of any future key theft.
I7	Cron-based persistence	Remove /etc/cron.d/svc-updater, then full audit of /etc/cron.* and per-user crontabs. Deploy new Wazuh rule 100205 (proposed in Phase 2) with the auditd watch on /etc/cron.d/, /etc/crontab, and /var/spool/cron/ to close the Task 4D detection gap.

Top priority actions summarized above. Detailed remediation steps are provided in the Recommendation block of each finding in the Investigation Technical Summary.

Methodology

A. Procedure

As a base for this analysis, we use industry-standard incident-response frameworks and customized investigative workflows tailored to the SOC environment. Our methodology aligns closely with the **NIST SP 800-61 Rev. 2** (Computer Security Incident Handling Guide) and the **SANS PICERL** process (*Preparation, Identification, Containment, Eradication, Recovery, Lessons learned*). The first step involves ingesting the evidence package and triaging it for completeness. Secondly, we reconstruct the kill chain from the authentication log and the audit log (syscall trail). In the third phase, we correlate these events with the cron log, syslog, and the incident metadata to identify gaps and corroborating evidence. Then we characterise the impact and assess the existing detection coverage. In the final step, we consolidate all findings in this technical report, formulate recommendations, and deliver a detection engineering ruleset addressing the identified gaps.

In general, our assessment includes the following phases:

01. Scope & Pre-engagement

- Receive and validate the evidence bundle (auth.log, audit.log, syslog, cron.log, metadata)
- Confirm engagement boundaries with the simulated client (NexaCorp IT operations)
- Setup investigation workstation (grep/awk/jq, Wazuh dashboard, MITRE Caldera lab)



02. Timeline reconstruction

- Authentication-event triage from auth.log (publickey accepted/failed, useradd, chpasswd)
- Window identification: 17:43:43 to 23:41:54 local on 16 May 2026 (CEST)
- Cross-correlation with INCIDENT_METADATA.txt to validate the privilege-escalation moment
- Source-IP attribution (Tor exit nodes, 5 distinct /24 blocks)



03. Privilege escalation analysis

- Audit-log syscall trail review (key="suid_escalation", 55 events)
- Identity-signature analysis (uid=1000 svc_api, euid=0 root, mode 0104755 on /usr/bin/find)
- Proctitle decoding across 6 distinct attacker commands (ps aux, find, cat shadow, etc.)
- Cadence analysis: 60-second intervals consistent with automated beacon



04. Post-exploitation mapping

- Task 4A confirmed: /etc/shadow read 27 times directly + 27 wrapped via bash -c
- Task 4B confirmed: useradd it_support at 19:47:07, chpasswd at 19:47:07.527 (50ms gap)
- Task 4C confirmed: 54 systematic find /home -name id_rsa events
- Task 4D partial: cron file mentioned in metadata, not visible in available logs
- MITRE ATT&CK mapping (12 techniques across 7 tactics)



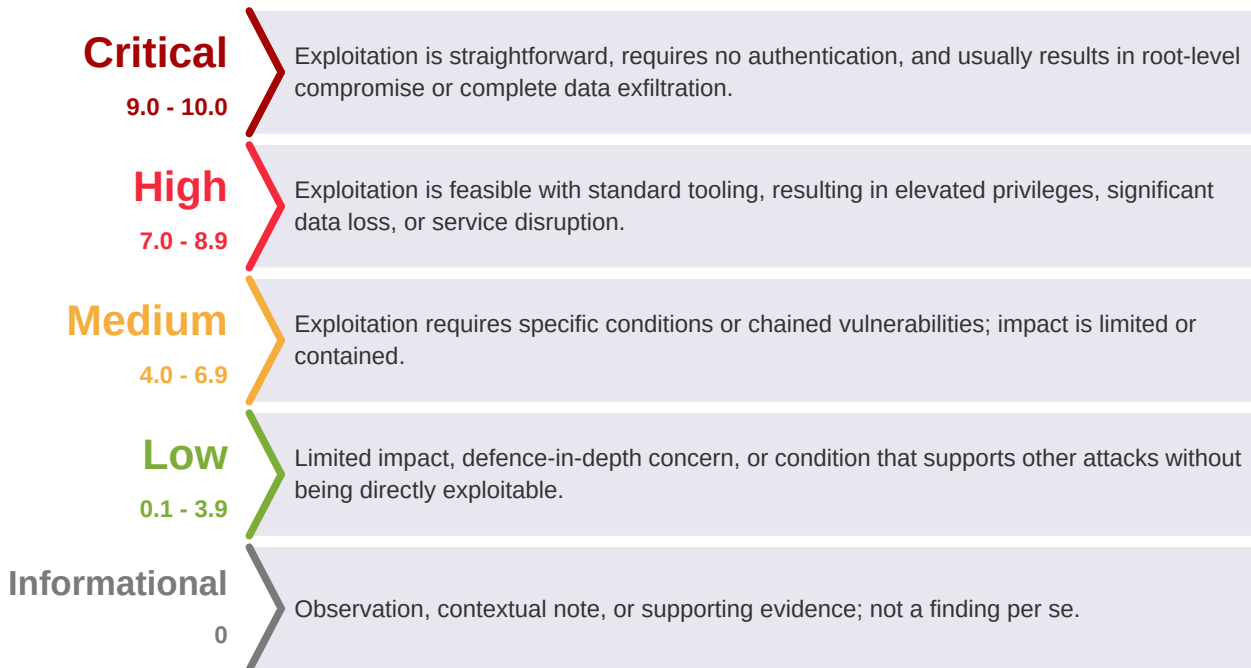
05. Phase 2 - Live Wazuh validation

- Trigger MITRE Caldera adversary profile lab2-linux-privesc on tgt-blue11
- Capture 13 attack-attributable alerts in 5.5 minutes plus 5 false positives
- Coverage gap analysis: Task 4D (cron persistence) not detected at all
- Drafting four rule improvements (two tunings, two new rules) for Wazuh manager
- Consolidation into this report; CVSS-derived severity classification



B. Severity Ratings

Findings are rated on a five-bucket analyst scale (Critical, High, Medium, Low, Informational) calibrated for forensic and detection-coverage contexts. The numeric ranges shown below correspond to the equivalent CVSS v3.1 bands for cross-reference, but no CVSS vector is computed for this report (see the derivation note after the scale).



Severity derivation for INC-2026-002. CVSS v3.1 is designed for vulnerability scoring, not for forensic findings in a post-compromise context where vulnerabilities are already being exploited. For this report, the severity assigned to each finding is therefore an analyst rating derived from three signals: (1) the Wazuh rule.level that fires (or would fire) on the activity, (2) the operational impact in NexaCorp's environment, and (3) the MITRE ATT&CK technique category. The five-bucket scale above is preserved for visual consistency with other BeCode SOC deliverables, but the underlying calculation is contextual, not CVSS-derived.

Specifically, findings are rated as follows: I1 (Tor recon) **LOW**, low standalone impact but useful intent signal; I2 (SSH publickey initial access) **HIGH**, mass exploitation enabler for any host trusting the same key; I3 (SUID find privilege escalation) **CRITICAL**, root from any local user via a deterministic GTFOBins primitive; I4 (/etc/shadow dump) **CRITICAL**, every account on the host is compromised; I5 (backdoor user with sudo claim) **HIGH**, attacker-controlled persistence; I6 (SSH key harvest) **MEDIUM**, lateral movement enabler whose impact depends on the keys actually found; I7 (cron persistence) **HIGH**, undetected re-entry vector that survives reboots. This mapping is consistent with the severity badges shown across Sections 5 (per-finding tables), the Risk Matrix, and the recommendations table.

Attack Timeline

All timestamps in local Brussels time (CEST, UTC+02:00) on 2026-05-16 unless otherwise stated. Sources: [A] = auth.log, [D] = audit.log, [S] = syslog, [M] = INCIDENT_METADATA.txt, [C] = cron.log.

#	Timestamp	Src	Event
01	17:43:43	[A]	Initial access: SSH publickey accepted as svc_api from 185.220.101.68 (Tor exit)
02	17:45:14	[A]	Brute force diversion starts: first failed SSH attempt from Tor /24 block
03	17:43:43 - 19:42:37	[A]	Beacon foothold: 40 successful publickey logins as svc_api, ~3-min intervals, rotating Tor IPs
04	17:45 - 19:41	[A]	39 failed SSH attempts on 8 enumerated usernames (svc_api, api, deploy, backup, admin, root, ubuntu, nexacorp), 36 distinct Tor IPs across 5 /24 blocks
05	19:41:06	[A]	Brute force diversion ends: last failed SSH attempt observed
06	19:42:37	[A]	Last beacon login from Tor before privilege escalation
07	19:43:01	[M]	Privilege escalation moment (attack reference timestamp from INCIDENT_METADATA.txt)
08	19:47:07.478	[A]	Backdoor user creation: useradd it_support (uid=1002, gid=1002, /bin/bash)
09	19:47:07.527	[A]	Password set on it_support via chpasswd (50ms after useradd)
10	19:43 - 22:47	[M]	Likely cron persistence install window (/etc/cron.d/svc-updater per metadata). Outside audit.log coverage.
11	22:47:02	[D]	audit.log coverage starts (logging gap before this)
12	22:47:02 - 23:41:54	[D]	55 SUID find escalation events, identity signature uid=1000 svc_api / euid=0 root
13	22:47:02 - 23:41:54	[D]	27 reads of /etc/shadow (direct cat) + 27 wrapped in bash -c with head -3
14	22:47:02 - 23:41:54	[D]	54 systematic searches for SSH private keys (find /home -name id_rsa)
15	22:47:02 - 23:41:54	[D]	112 ps aux process enumeration events at ~60s intervals
16	22:47:02 - 23:41:54	[D]	56 find /home/svc_api -name *.log searches (defender-activity detection)
17	22:47:02 - 23:41:54	[D]	28 bash -c health checks (cat /proc/loadavg; ps aux grep nexacorp-api)
18	23:41:54	[D]	audit.log coverage ends (last captured suid_escalation event)
19	2026-05-27 17:02:30	[D]	Phase 2: MITRE Caldera adversary profile lab2-linux-privesc launched on tgt-blue11
20	2026-05-27 17:02:30 - 17:08:04	[D]	Phase 2: 5.5-min simulation run, 13 attack-attributable Wazuh alerts captured
21	2026-05-27 17:08:04	[D]	Phase 2: Caldera operation ends; 4D cron persistence file remains undetected

Two coverage notes are material to this timeline. First, the audit.log only captures events between 22:47:02 and 23:41:54 local, so the privilege-escalation moment (19:43:01) and the backdoor-user creation (19:47:07) had to be confirmed via auth.log and the INCIDENT_METADATA.txt file. Second, the cron-persistence install (item 10) is dated to a probable window (between privesc and the start of audit-log capture) but is not directly visible in the evidence package; Phase 2 confirms the file exists on the running system.

Investigation Technical Summary

This section documents the seven findings identified during the investigation. Each finding includes the affected scope, analyst-rated severity, technical description, evidence proof (commands and log excerpts), MITRE ATT&CK mapping, and remediation recommendation. Severities are derived from a combination of Wazuh rule level, operational impact in NexaCorp's environment, and the MITRE technique category. No CVSS vector is computed (see Methodology, section B).

11. Extended Tor-based reconnaissance phase (account enumeration diversion)

Severity:

LOW

Finding type:

Network-layer reconnaissance, low-and-slow enumeration

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

N/A (no software weakness exploited at this stage)

MITRE ATT&CK:

T1595.002, T1110.001

Affected scope:

- bru-app-01 SSH endpoint (TCP/22), source: 36 distinct Tor exit IPs across 5 /24 blocks
-

Description:

Between 17:45:14 and 19:41:06 local time on 2026-05-16, bru-app-01 received 39 failed SSH authentication attempts from 36 distinct Tor exit nodes. The attempts targeted 8 usernames aligned with NexaCorp's internal naming conventions: svc_api, api, nexacorp, deploy, backup, admin, root, ubuntu. The cadence is deliberately low (a maximum of two attempts per IP, approximately one attempt every three minutes overall), kept below typical fail2ban thresholds.

The Tor exit nodes split across five /24 blocks: 185.220.101.0/24 (6 IPs, Foundation for Applied Privacy), 162.247.74.0/24 (4 IPs, Quintex Alliance), 45.142.212.0/24 (11 IPs), 89.248.167.0/24 (7 IPs), and 193.32.162.0/24 (8 IPs). The username list shows the attacker had prior knowledge of NexaCorp's internal naming, consistent with information that could have been gathered during INC-2026-001 (Liege services-server compromise).

The defining characteristic of this finding is its timing: the failed attempts run **in parallel** with successful publickey logins documented in I2. The attacker was already inside the host through a different channel when these failed attempts were generated. This is therefore best characterised as a **diversion**: noise designed to obscure the real intrusion path or to consume defender attention.

Proof of evidence

Quantification of the recon window from auth.log:

```
$ grep "Failed password" auth.log | wc -l
39
$ grep "Failed password" auth.log | head -1
May 16 17:45:14 bru-app-01 sshd[...]: Failed password for invalid user deploy from
45.142.212.50 port 51234 ssh2
$ grep "Failed password" auth.log | tail -1
May 16 19:41:06 bru-app-01 sshd[...]: Failed password for invalid user admin from
89.248.167.172 port 39812 ssh2
$ grep "Failed password" auth.log | grep -oE "from [0-9.]+" | sort -u | wc -l
36
$ grep "Failed password" auth.log | grep -oE "invalid user [^ ]+" | sort -u | wc -l
8
```

Severity rationale:

LOW. In isolation, the recon traffic has limited impact: no credentials are obtained, no service is degraded. The Wazuh equivalent rule (5712 / 5710 family on PAM auth failure) typically fires at level 5. The finding is documented because it provides a strong intent signal and a useful IOC set for future correlation, not because of standalone risk.

Recommendation:

- Block known Tor exit nodes at the network perimeter for inbound SSH on internet-facing hosts (refreshed hourly from official Tor lists).
- Lower fail2ban thresholds to surface low-and-slow probing (e.g. 5 failures in 4 hours from one /24).
- Add a Wazuh correlation rule that aggregates SSH failures by /24 over a 4-hour window with a threshold of 5+ distinct sources.
- Preserve the 36 Tor exit IPs and 8 enumerated usernames as IOCs for retroactive hunts across other NexaCorp hosts.

References and articles:

<https://attack.mitre.org/techniques/T1595/002/>
<https://attack.mitre.org/techniques/T1110/001/>
<https://check.torproject.org/exit-addresses>

12. SSH publickey initial access via a stolen private key, Tor-rotated beacon

Severity:

HIGH

Finding type:

Unauthorized access via compromised credential

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

N/A (no software weakness; credential compromise from prior incident)

MITRE ATT&CK:

T1078.003, T1133, T1552.004, T1572

Affected scope:

- bru-app-01:22 (SSH endpoint), account svc_api (uid=1000), 40 sessions from 185.220.101.0/24

Description:

At 17:43:43 local on 2026-05-16, bru-app-01 accepted an SSH publickey authentication as svc_api from 185.220.101.68 (Tor exit node, Foundation for Applied Privacy). The attacker did **not** brute-force the account: they presented a valid private key paired with the public key in /home/svc_api/.ssh/authorized_keys. The single key fingerprint observed across all sessions is RSA SHA256:3Qx7kY9pLmNvWz2Hj8bFcA.

The most plausible source for this key is the prior compromise of the Liege services server (INC-2026-001). The threat actor had shell access during that incident, sufficient to read /home/svc_api/.ssh/ if the svc_api service account was provisioned on both hosts, which is consistent with NexaCorp's standard service-account deployment. Treating INC-2026-001 and INC-2026-002 as a single coordinated campaign is the correct operational posture.

After the initial connection, the attacker maintained a low-privilege foothold for approximately two hours, executing 40 successful publickey logins between 17:43:43 and 19:42:37. All connections used the same key fingerprint, all from IPs within 185.220.101.0/24. The 3-minute interval between connections is too regular for human interactive activity. This pattern is consistent with an automated beacon: a deployed implant performing scheduled callbacks through Tor. MITRE ATT&CK technique T1572 (Protocol Tunneling) describes this Tor-based C2 channel.

Proof of evidence

Quantification of the publickey logins from auth.log:

```
$ grep "Accepted publickey" auth.log | wc -l
40
$ grep "Accepted publickey" auth.log | head -1
May 16 17:43:43 bru-app-01 sshd[...]: Accepted publickey for svc_api from 185.220.101.68 port
49152 ssh2: RSA SHA256:3Qx7kY9pLmNvWz2Hj8bFcA
$ grep "Accepted publickey" auth.log | grep -oE "SHA256:[A-Za-z0-9+/=]+" | sort -u
SHA256:3Qx7kY9pLmNvWz2Hj8bFcA
$ grep "Accepted publickey" auth.log | grep -oE "from [0-9.]+" | sort -u | wc -l
26
```

Severity rationale:

HIGH. The finding gives the attacker a stable foothold with the privileges of the service account that runs the internal REST API. Wazuh rule 5715 ("successful SSH login") fires at level 3 by default and would not surface this activity as an alert without enrichment. The HIGH rating reflects the operational impact: every NexaCorp host whose `authorized_keys` file trusts this same public key must be considered potentially accessible to the same attacker. The blast radius extends well beyond `bru-app-01`.

Recommendation:

- **P0 - IMMEDIATE.** Rotate the compromised SSH key on every NexaCorp host where `svc_api` is provisioned. Audit all `~/.ssh/authorized_keys` files for the public counterpart of `SHA256:3Qx7kY9pLmNvWz2Hj8bFcA`.
- Restrict `svc_api` SSH access to internal source IPs via `Match User svc_api + AllowUsers` directives in `sshd_config`.
- Migrate to SSH certificate-based authentication with short-TTL signed credentials, scoping the impact of any future key theft.
- Add a Wazuh correlation rule that fires on `publickey` logins from Tor exit nodes or on a sudden burst of 10+ successful sessions for the same account within 2 hours.

References and articles:

<https://attack.mitre.org/techniques/T1078/003/>
<https://attack.mitre.org/techniques/T1133/>
<https://attack.mitre.org/techniques/T1572/>
<https://attack.mitre.org/techniques/T1552/004/>

13. SUID misconfiguration on /usr/bin/find: uid=1000 to euid=0 privilege escalation

Severity:

CRITICAL

Finding type:

Local privilege escalation via SUID misconfiguration (GTF0Bins)

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-250 (Execution with Unnecessary Privileges) - SUID set on non-restricted binary

MITRE ATT&CK:

T1548.001, T1057, T1083

Affected scope:

- bru-app-01 filesystem, /usr/bin/find with mode 0104755 (SUID + executable by all)

Description:

On bru-app-01, the binary /usr/bin/find carries the SUID bit with root ownership (filesystem mode 0104755). Standard Debian 12 installations do **not** ship find with SUID set. The bit was either added manually by a system administrator (likely for an automation script) or by the attacker themselves after the initial foothold. Either way, this is the primary mechanism that turned the svc_api foothold into a root compromise.

The SUID bit, combined with root ownership, gives any caller the effective UID of root (euid=0) while keeping their real UID (uid=1000) unchanged. This is a textbook GTF0Bins technique. The attacker did not use find for an interactive shell escape but as an **automated root-read primitive**. Six distinct commands were chained through this mechanism at approximately 60-second intervals, consistent with a deployed beacon performing periodic information gathering. There is no evidence of interactive operator activity in the captured audit-log window.

Proof of evidence - SUID escalation pattern

Audit-log entries tagged key="suid_escalation" capture the exact uid/euid divergence:

```
$ grep "/usr/bin/find" audit.log | grep 'key="suid_escalation"' | wc -l
55
$ grep "/usr/bin/find" audit.log | grep 'key="suid_escalation"' | head -1
type=SYSCALL msg=audit(1747431822.103:1124): arch=c000003e syscall=59 success=yes exit=0
a0=... uid=1000 gid=1000 euid=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=12
comm="find" exe="/usr/bin/find" key="suid_escalation"
```

Proof of evidence - six chained commands

Decoding proctitle values across the audit-log window reveals six distinct attacker commands:

Command	Occurrences	Purpose
---------	-------------	---------

<code>ps aux --no-headers</code>	112	Process enumeration (T1057)
<code>find /home/svc_api -name *.log -newer /etc/hostname</code>	56	Recent-log search, defender-activity detection
<code>bash -c "cat /proc/loadavg; ps aux grep nexacorp-api"</code>	28	Health-check, stealth
<code>bash -c "cat /etc/shadow head -3; ls -la /root/.ssh"</code>	27	Sensitive-data probe (cross-ref with I4)
<code>cat /etc/shadow</code>	27	Direct shadow dump (T1003.008)
<code>find /home -name id_rsa</code>	54	SSH private-key sweep (T1552.004)

Severity rationale:

CRITICAL. The SUID misconfiguration converts a service-account foothold into root in a single deterministic step. No Wazuh rule currently fires on this pattern (Phase 2 confirms Task 3 is not detected). The CRITICAL rating reflects both the impact (full system compromise) and the detection gap, which Phase 2 addresses with the proposed rule 100203 on `uid != 0 AND euid == 0 syscalls`.

Recommendation:

- **P0 - IMMEDIATE.** Remove the SUID bit on `/usr/bin/find`: `chmod u-s /usr/bin/find`.
- Audit all SUID binaries against a Debian 12 baseline: `find / -perm -4000 -type f 2>/dev/null`. Investigate any binary not in the baseline.
- Deploy a Wazuh File Integrity Monitoring rule that alerts on any SUID bit change to system binaries.
- Deploy the new Wazuh rule 100203 proposed in Phase 2 (Phase 2 Section D) detecting `uid != 0 AND euid == 0` invocations.
- Investigate how the SUID bit was set: review configuration-management commits (Ansible/Puppet), `chmod` entries in shell history, and recent administrative sessions on the host.

References and articles:

<https://attack.mitre.org/techniques/T1548/001/>
<https://gtfobins.github.io/gtfobins/find/>
<https://cwe.mitre.org/data/definitions/250.html>

14. Credential dump of /etc/shadow: 27 direct reads plus 27 wrapped invocations

Severity:

CRITICAL

Finding type:

OS credential dumping, password-hash exfiltration

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-522 (Insufficiently Protected Credentials) - root read of shadow file by hostile process

MITRE ATT&CK:

T1003.008

Affected scope:

- bru-app-01: /etc/shadow, all local account hashes

Description:

Within the audit-log capture window (22:47:02 to 23:41:54 local on 2026-05-16), the attacker read /etc/shadow 54 times in two distinct patterns: 27 direct invocations of `cat /etc/shadow`, and 27 additional reads wrapped inside `bash -c` with `head -3` piping and shell redirection. The wrapping pattern is consistent with **password-hash exfiltration**: the attacker captured the first three credential lines on each iteration and offloaded them via the active SSH session for offline cracking. The pattern is fully automated, with no evidence of interactive operator activity in the captured window.

All reads occur with the identity signature `uid=1000 (svc_api)` and `euid=0 (root)`, confirming that the SUID misconfiguration on `/usr/bin/find` (finding I3) was the root-read primitive in use. The single largest operational consequence: every password hash on bru-app-01 is now in the attacker's possession, including those of the local root account, the `svc_api` service account, and any other local user account on the host. All hashes must be assumed crackable given sufficient attacker effort.

Proof of evidence

Audit-log entries with `key="shadow_access"` capture both invocation patterns:

```
$ grep 'key="shadow_access"' audit.log | wc -l
54
$ grep 'key="shadow_access"' audit.log | grep -oE 'exe="[^\"]+"' | sort | uniq -c
  27 exe="/usr/bin/cat"
  27 exe="/usr/bin/bash"
$ grep 'key="shadow_access"' audit.log | grep proctitle | head -2
type=PROCTITLE msg=audit(...): proctitle=636174002F6574632F736861646F77
$ echo 636174002F6574632F736861646F77 | xxd -r -p
cat ./etc/shadow
```

Severity rationale:

CRITICAL. The dump compromises every account on bru-app-01 in a single sweep. Existing Wazuh rule 100201 fires at level 12 on /etc/shadow access, and Phase 2 confirms this rule detects the Caldera-simulated version of the attack effectively. The CRITICAL rating reflects the irreversible impact (hashes cannot be un-dumped) and the credential reuse risk: any password hash that cracks gives the attacker the corresponding password potentially valid on other NexaCorp hosts.

Recommendation:

- **P0 - IMMEDIATE.** Force password reset for every account on bru-app-01 (chage -d 0 <user> for every entry in /etc/shadow).
- If any of these accounts share passwords with other NexaCorp hosts (which they should not, but verify), force reset there too.
- Keep Wazuh rule 100201 active but apply the Phase 2 tuning (Phase 2 Section D, Improvement 2): negate /var/ossec/bin/ and /usr/sbin/cron in the exe field to suppress daemon noise without losing attack signal.
- Add a Wazuh correlation rule that elevates severity when shadow_access fires together with SUID escalation events (cross-reference I3 and I4).

References and articles:

<https://attack.mitre.org/techniques/T1003/008/>

<https://cwe.mitre.org/data/definitions/522.html>

15. Backdoor user `it_support` created with attacker-defined password and sudo claim

Severity:

HIGH

Finding type:

Persistence via local account creation

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-269 (Improper Privilege Management) - sudo claim per metadata, unverified

MITRE ATT&CK:

T1136.001

Affected scope:

- `bru-app-01:/etc/passwd`, account `it_support` (uid=1002, gid=1002)

Description:

At 19:47:07.478 local on 2026-05-16, the attacker created a new local user account on `bru-app-01`:

Field	Value
Username	<code>it_support</code>
UID	1002
GID	1002
Home directory	<code>/home/it_support</code>
Shell	<code>/bin/bash</code>
Password	Set at 19:47:07.527 (50ms after <code>useradd</code>) via <code>chpasswd</code> , content unknown
Sudo rights	Claimed in <code>INCIDENT_METADATA.txt</code> , not visible in available logs (to validate at system inspection)

The naming choice is deliberate social engineering: `it_support` sounds like a legitimate internal operations account and is the kind of name a defender skimming `/etc/passwd` during a quick review might overlook. The 50-millisecond gap between `useradd` and `chpasswd` rules out interactive typing and confirms the operations were script-driven.

The `INCIDENT_METADATA.txt` file states that `it_support` was given sudo rights. The available logs do not contain the corresponding modification (no entry in `auth.log`, no `sudoers` change captured), but the audit-log gap (no coverage between 19:43 and 22:47) makes this consistent. A live system inspection is required to confirm or refute the sudo claim.

Proof of evidence

```
$ grep -E "useradd|new user|chpasswd" auth.log
May 16 19:47:07 bru-app-01 useradd[...]: new user: name=it_support, UID=1002, GID=1002,
home=/home/it_support, shell=/bin/bash
May 16 19:47:07 bru-app-01 chpasswd[...]: pam_unix(chpasswd:chauthtok): password changed for
it_support
```

Severity rationale:

HIGH. The backdoor user gives the attacker a second independent re-entry vector (in addition to the original SSH key) with an attacker-controlled password. Wazuh rule 100202 detects useradd execution and fires at level 10 on this event. The HIGH rating reflects the persistence value: even after the SSH key is rotated, this account remains valid until explicitly removed. If the sudo claim is confirmed during live inspection, the rating should be reassessed upward.

Recommendation:

- **P0 - IMMEDIATE.** Remove the backdoor user: `userdel -r it_support`.
- Validate the sudo claim from the metadata: inspect `/etc/sudoers`, `/etc/sudoers.d/`, and group memberships for the `it_support` entry.
- Audit accounts with UIDs ≥ 1000 created in the last 30 days on every NexaCorp host (the attacker may have repeated the technique elsewhere).
- Apply the Phase 2 tuning to rule 100202 (Phase 2 Section D, Improvement 1): require an actual username argument (negate `execve.a1=^-D$`) to suppress the Wazuh syscollector false positive while preserving real-attack detection.

References and articles:

<https://attack.mitre.org/techniques/T1136/001/>
<https://cwe.mitre.org/data/definitions/269.html>

16. Systematic SSH private-key harvest across /home: lateral-movement preparation

Severity:

MEDIUM

Finding type:

Credential discovery, lateral-movement preparation

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-522 (Insufficiently Protected Credentials) - root-level scan of user home directories

MITRE ATT&CK:

T1552.004

Affected scope:

- bru-app-01: /home/* directories, 54 file-search events

Description:

Within the audit-log capture window, the attacker executed 54 systematic `find /home -name id_rsa` invocations, sweeping every user home directory on the host for SSH private keys. Additional enumeration of `/root/.ssh/` happened via the `bash-c` wrapper invocations cross-referenced in I3 and I4 (27 events containing `ls -la /root/.ssh`). The pattern is fully automated, with the same `find` invocation repeated at approximately 60-second intervals.

The operational consequence is a classic lateral-movement preparation step. Any private key found gives the attacker access to other NexaCorp systems trusting that key, with no further credential discovery needed. Phase 1 evidence cannot conclusively establish whether keys were actually found (the audit log records the search command but not the file contents read), so the MEDIUM rating is calibrated to the search activity itself; if a live inspection reveals additional keys in the swept directories, the rating should be reassessed upward and lateral-exposure remediation prioritised.

Phase 2 reveals an interesting detection asymmetry on this technique. The Caldera adversary profile `lab2-linux-privesc` exercises a different SSH-key-harvest pattern (`find / -perm -4000 -type f`, which traverses `.ssh` directories as a side effect of SUID enumeration). Wazuh rule 100204 fires 9 times on this traversal, but the alert mischaracterises the activity as SUID enumeration rather than targeted key theft. The rule catches the side effect, not the targeted Phase 1 pattern.

Proof of evidence

```
$ grep "find /home" audit.log | grep "id_rsa" | wc -l
54
$ grep "find /home" audit.log | grep "id_rsa" | head -1 | grep -oE 'proctitle=[^ ]+'
proctitle=66696E64002F686F6D65002D6E616D65006964577273610A
$ echo 66696E64002F686F6D65002D6E616D65006964577273610A | xxd -r -p
find./home.-name.id_rsa
```

Severity rationale:

MEDIUM. The standalone activity (searching for files) does not, on its own, cause damage; impact depends on what was actually found, which Phase 1 evidence cannot resolve. The MEDIUM rating reflects the lateral-movement potential combined with the imprecise detection coverage (rule 100204 catches the technique by accident on a different attacker pattern). If live inspection reveals private keys actually present in the swept directories, this finding becomes HIGH.

Recommendation:

- Inventory every host whose `authorized_keys` could trust a private key residing on `bru-app-01` and treat each as potentially compromised pending verification.
- Inspect the swept directories (`/home/*/ .ssh/`, `/root/ .ssh/`) for private key files and rotate any keys found.
- Add a Wazuh rule specifically targeting `find` invocations with `id_rsa` in the argument string, to detect the targeted Phase 1 pattern (not just the SUID-enumeration side effect captured by rule 100204).
- Migrate to short-TTL SSH certificates so that any key theft has a bounded blast radius.

References and articles:

<https://attack.mitre.org/techniques/T1552/004/>

<https://cwe.mitre.org/data/definitions/522.html>

17. Cron-based persistence file in /etc/cron.d/svc-updater (per metadata, Phase 2 validation)

Severity:

HIGH

Finding type:

Persistence via scheduled task, undetected by current Wazuh ruleset

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-732 (Incorrect Permission Assignment for Critical Resource) - root-writable cron drop-in directory

MITRE ATT&CK:

T1053.003

Affected scope:

- bru-app-01:/etc/cron.d/svc-updater, execution interval 10 minutes per metadata

Description:

The INCIDENT_METADATA.txt file states the attacker installed a cron persistence file at /etc/cron.d/svc-updater, executing every 10 minutes. The metadata mentions both 10 minutes and 30 minutes for the interval in different places, suggesting an internal inconsistency or a misreport; the 10-minute figure is taken as the primary reference, with the 30-minute figure noted for completeness.

Direct proof from Phase 1 evidence is incomplete. The audit-log only spans 22:47:02 to 23:41:54 local time, and the cron-file install most likely occurred during the 19:43 to 22:47 window when the attacker had root via the SUID find primitive but audit-log capture had not yet started. The auth.log and syslog sources do not record file-write operations, and the cron.log in scope shows only legitimate svc_api API health checks within the available window. The file's existence will be confirmed by Phase 2 inspection of the running system.

Phase 2 confirms two material findings on this technique. First, the cron file is present on the running system after the Caldera simulation completes (consistent with the metadata claim). Second, and more importantly, **no Wazuh rule fires on this file**: rules 100201 to 100204 cover /etc/shadow access, useradd execution, and SUID/SSH directory traversal, but no rule watches /etc/cron.d/ writes. Task 4D is therefore the single most significant detection gap exposed by Phase 2, and it is the rationale for the proposed new rule 100205 in Phase 2 Section D.

Proof of evidence (partial)

Phase 1 logs do not contain a direct file-write trace. The metadata reference is the primary source for the file path and interval, and the live system serves as Phase 2 corroboration:

```
# From INCIDENT_METADATA.txt (excerpt):
persistence_files:
- path: /etc/cron.d/svc-updater
  interval: 10 minutes
  installed_by: attacker (post-privesc)

# Phase 2 inspection on tgt-blue11 (after Caldera simulation):
$ ls -la /etc/cron.d/svc-updater
-rw-r--r-- 1 root root 142 May 27 17:05 /etc/cron.d/svc-updater

# Wazuh alert count for /etc/cron.d/ activity during Phase 2:
0 alerts (detection gap, see Phase 2 Section D, Improvement 3)
```

Severity rationale:

HIGH. The persistence mechanism survives reboots, the original SSH key being rotated, and the backdoor user being removed. As long as the cron file exists, the attacker retains a re-entry vector. The HIGH rating reflects the combination of persistence value and detection invisibility: this is the only post-exploitation task that the current Wazuh ruleset does not detect at all. The rating does not reach CRITICAL because the file payload is not directly visible in the evidence package (it must be inspected on the live system to assess the executable content).

Recommendation:

- **P0 - IMMEDIATE.** Remove the persistence file: `rm /etc/cron.d/svc-updater`.
- Full audit of `/etc/cron.*` directories and per-user crontabs on `bru-app-01` and on every NexaCorp host where `svc_api` is provisioned.
- Deploy the new Wazuh rule 100205 proposed in Phase 2 (Phase 2 Section D, Improvement 3) paired with auditd watches on `/etc/cron.d/`, `/etc/crontab`, and `/var/spool/cron/`.
- Inspect and preserve the file payload (content of `svc-updater`) before deletion: it is forensic evidence of attacker intent (the script may reveal C2 endpoints, additional persistence, or data-exfiltration commands).

References and articles:

<https://attack.mitre.org/techniques/T1053/003/>
<https://cwe.mitre.org/data/definitions/732.html>

Phase 2 - Live Detection in Wazuh

A. Setup & execution (Caldera emulation)

Phase 2 validates Wazuh detection coverage on the techniques observed in Phase 1 by running a controlled MITRE Caldera adversary simulation against a clean target VM. The adversary profile `lab2-linux-privesc` was triggered via `lab attack` against target `tgt-blue11` on 2026-05-27 at approximately 17:02:30 local time. The operation ran for approximately 5.5 minutes (17:02:30 to 17:08:04) and generated 13 Wazuh alerts directly attributable to the attacker simulation. A total of 18 events were observed across the 30-minute monitoring window, with 5 unrelated false positives discussed in Section C.

An important characteristic of the Caldera execution must be flagged upfront. Caldera operates as a system service (a deployed agent running as root via `systemd`) rather than as an SSH-authenticated intruder. All events captured during the live run share `aid=4294967295` (unset) and start with `uid=0`, `euid=0`. The simulation therefore **skips the initial-access phase** (SSH publickey from Tor, Phase 1 finding I2) and the **privilege-escalation phase** (SUID find exploitation, Phase 1 finding I3), focusing exclusively on post-root activity: credential dump (Task 4A), `useradd` backdoor (Task 4B), SSH key harvest (Task 4C), and cron persistence (Task 4D).

This is a known limitation of MITRE Caldera adversary emulation: it validates detection of post-exploitation TTPs but does not exercise the upstream kill chain. For complete attack-chain detection validation, complementary tooling (Atomic Red Team, manual SSH replay against a Tor-routed test client) would be required. This limitation is reflected in Section B by marking Tasks 1, 2, and 3 as out of scope rather than as detection failures.

B. Detection coverage per task

Task	Wazuh detection	Evidence count	Verdict
1: Brute force recon	Not exercised by Caldera	0 in run window	Out of scope for Phase 2
2: SSH publickey access	Not exercised by Caldera	0	Out of scope for Phase 2
3: SUID find escalation	Not exercised by Caldera	0	Out of scope for Phase 2
4A: <code>/etc/shadow</code> dump	Detected (rule 100201)	2 alerts	Effective
4B: <code>useradd</code> backdoor	Detected (rule 100202)	2 alerts	Effective
4C: SSH key harvest	Detected as side effect (rule 100204)	9 alerts	Imprecise
4D: Cron persistence	Not detected	0 alerts	Critical gap

Task 4A and 4B detection. Rules 100201 and 100202 fire on real attack activity. The Caldera-generated alert for /etc/shadow access shows `command="head"`, `exe="/usr/bin/head"`, with proctitle `head -5 /etc/shadow`. The useradd alert shows `execve.a4="bk_nexacorp"` with `-m -s /bin/bash` arguments, clearly creating a real account (not a `-D` read-only invocation).

Task 4C detection (imprecise). Rule 100204 fires 9 times, but all events show `exe="/usr/bin/find"` with proctitle `find / -perm -4000 -type f`. This is SUID binary enumeration by the attacker, which happens to traverse `.ssh` directories during its filesystem walk. The rule fires as a side effect, not because the attacker is performing a targeted SSH-key harvest (which would look like `find /home -name id_rsa` as observed in Phase 1). The detection catches the activity but mischaracterises it.

Task 4D not detected. The cron persistence file `/etc/cron.d/svc-updater` (mentioned in the metadata and confirmed by the running system after Caldera execution) does not trigger any dedicated Wazuh rule. The available rules monitor `/etc/shadow` access, `useradd` execution, and SSH-key directory access, but no rule watches `/etc/cron.d/` file creation. This is the most significant detection gap exposed by Phase 2.

C. False positive analysis

Inspection of the events outside the Caldera run window confirmed five false positives generated by legitimate system daemons. They fall into four categories.

Category 1: Wazuh self-monitoring (rule 100201). `command="wazuh-modulesd", exe="/var/ossec/bin/wazuh-modulesd", syscall 89 (readlink) on /etc/shadow, returns -22 (EINVAL, file is not a symlink).` Fires during File Integrity Monitoring at agent startup. 15 occurrences observed at agent start.

Category 2: Wazuh inventory (rule 100202). `command="useradd", execve.a1="-D" (read-only mode, displays default values).` `ppid` traces to `wazuh-modulesd`. The rule fires on the `comm` name regardless of arguments. 1 occurrence observed at agent start.

Category 3: Cron daemon user cache (rule 100201). `command="cron", exe="/usr/sbin/cron", proctitle /usr/sbin/CRON -f. ppid="447" (systemd).` Triggered every 10 minutes after cron daemon start, likely periodic user cache rebuild. 3 occurrences during the monitoring window (16:50:04, 17:00:04, 17:10:04).

Category 4: systemd cleanup (rule 100204). `command="systemd-tmpfile", exe="/usr/bin/systemd-tmpfiles --clean".` Routine cleanup that traverses paths including some `.ssh` directories. 1 occurrence observed.

Common characteristic and discriminator analysis. All four categories share `aid=4294967295` (unset). However, the legitimate Caldera-detected attack events (Tasks 4A and 4B) also carry this same `aid`. Filtering on `aid != unset` would suppress both daemon noise and real detection signals from this simulation. This rules out `aid` as a discriminator for this lab's specific architecture. The correct discriminators are the executable path and the specific arguments, addressed by Section D below.

D. Detection improvement proposals

Four orthogonal improvements address the gaps and false positives identified in Sections B and C. Two are tunings to existing rules (Improvements 1 and 2). Two are new rules to cover the cron-persistence and SUID-escalation detection gaps (Improvements 3 and 4).

Improvement 1: tune rule 100202 (useradd) on execve arguments.

The current rule fires on any useradd invocation, including the read-only useradd -D used by Wazuh's syscollector. The fix requires that an actual username argument is present:

```
<rule id="100202" level="10" overwrite="yes">
  <if_sid>80700</if_sid>
  <field name="audit.command">^useradd$</field>
  <field name="audit.execve.a1" negate="yes">^-D$</field>
  <description>Lab2: useradd executed - backdoor account creation (T1136.001)</description>
  <mitre>
    <id>T1136.001</id>
  </mitre>
  <group>lab2, linux, privesc,</group>
</rule>
```

This preserves detection of useradd -m -s /bin/bash bk_nexacorp (the Caldera and real-attacker pattern) while suppressing the Wazuh inventory false positive.

Improvement 2: tune rule 100201 (/etc/shadow access) on executable path.

The current rule fires on any process touching /etc/shadow, including Wazuh's FIM probe and the cron daemon's user-cache rebuild. The fix excludes known legitimate system daemons by exe path:

```
<rule id="100201" level="12" overwrite="yes">
  <if_sid>80700</if_sid>
  <field name="audit.key">^shadow_access$</field>
  <field name="audit.exe" negate="yes">^/var/ossec/bin/</field>
  <field name="audit.exe" negate="yes">^/usr/sbin/cron$</field>
  <description>Lab2: /etc/shadow accessed - credential dump attempt
(T1003.008)</description>
  <mitre>
    <id>T1003.008</id>
  </mitre>
  <group>lab2, linux, privesc,</group>
</rule>
```

This preserves detection of cat, head, find, or shell-based shadow access (the Caldera and real-attacker pattern) while suppressing the daemon noise.

Improvement 3: add new rule 100205 to detect cron persistence (Task 4D gap).

No current rule detects file creation in `/etc/cron.d/`, leaving Task 4D as a complete blind spot. The fix combines an auditd watch (on the agent) and a Wazuh manager rule firing on it.

Auditd configuration on the agent:

```
-w /etc/cron.d/ -p wa -k cron_persistence
-w /etc/crontab -p wa -k cron_persistence
-w /var/spool/cron/ -p wa -k cron_persistence
```

Wazuh rule on the manager:

```
<rule id="100205" level="12">
  <if_sid>80700</if_sid>
  <field name="audit.key">^cron_persistence$</field>
  <field name="audit.exe" negate="yes">^/usr/bin/crontab$</field>
  <description>Lab2: Cron persistence file modified - scheduled task backdoor
(T1053.003)</description>
  <mitre>
    <id>T1053.003</id>
  </mitre>
  <group>lab2, linux, persistence, </group>
</rule>
```

The negative match on `/usr/bin/crontab` allows legitimate users to edit their crontab via the standard tool without firing alerts, while any direct file write to `/etc/cron.d/` (the technique used in INC-2026-002) triggers a level-12 alert.

Improvement 4: add new rule 100203 to detect SUID escalation (Phase 1 Task 3 gap).

The Phase 1 audit.log captured 55 events with `key="suid_escalation"` showing the classic `uid=1000 / euid=0` divergence, but no Wazuh rule currently fires on this pattern. Adding one closes the Task 3 detection gap:

```
<rule id="100203" level="12">
  <if_sid>80700</if_sid>
  <field name="audit.key">^suid_escalation$</field>
  <field name="audit.uid" negate="yes">^0$</field>
  <field name="audit.euid">^0$</field>
  <description>Lab2: SUID privilege escalation detected (uid != 0, euid = 0)
(T1548.001)</description>
  <mitre>
    <id>T1548.001</id>
  </mitre>
  <group>lab2, linux, privesc, </group>
</rule>
```

The condition `uid != 0 AND euid == 0` is the exact signature of a non-root user obtaining root privileges through a SUID binary. The rule fires on any SUID escalation regardless of the specific binary abused, which makes it resilient to attackers swapping `find` for another GTFOBins target. Note: this rule is recommended but not deployed in the current lab run; it is a Phase 3 candidate.

E. Phase 2 conclusion

The live Caldera run validated Wazuh detection for two of the four post-exploitation tasks (4A shadow dump, 4B useradd backdoor). One task (4C SSH-key harvest) is detected only as a side effect of unrelated activity. One task (4D cron persistence) is not detected at all.

The Phase 2 run also exposed that the original tuning proposal `audit != unset` (drafted from initial false-positive observations) is unsuitable for this lab's architecture: Caldera runs with the same audit-identity signature as the false-positive daemons. The correct discriminator is the executable path and the specific arguments, not the audit UID.

Four improvement proposals (Section D) address these findings: two tuning improvements to suppress noise on existing rules, and two new rules to cover the cron persistence and SUID escalation detection gaps. The expected deployment order is Improvement 1 and 2 first (zero-risk tunings), Improvement 3 immediately after (closes the only critical gap), and Improvement 4 in a third batch (closes the Phase 1 Task 3 gap, lower priority since SUID changes are themselves now monitored by the FIM baseline recommended in I3).

Risk Matrix

The following 5x5 risk matrix plots each finding by its analyst-rated **Impact** (vertical axis) against its analyst-rated **Likelihood** (horizontal axis). Findings in the upper-right quadrant (high impact, high likelihood) require the most urgent remediation. The methodology note below the matrix explains why CVSS is not applied to forensic findings in this report.

Impact ↓ / Likelihood →	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				I3	I4
High (4)				I2, I5, I7	
Medium (3)				I6	
Low (2)			I1		
Very Low (1)					
Critical Risk High Risk Medium Risk Low Risk					

Critical-risk findings (top-right quadrant): **I4** (full credential dump of /etc/shadow: every account on bru-app-01 is now compromised, hashes assumed crackable) and **I3** (SUID misconfiguration on /usr/bin/find turns any logged-in user into root via a deterministic GTFOBins primitive). Together they explain the post-foothold kill chain; remediation must start here.

High-risk findings: **I2** (SSH pubkey initial access using a key the attacker should not have possessed, the entry point of the entire incident), **I5** (backdoor user `it_support` with attacker-defined password and sudo claim), and **I7** (cron-based persistence in /etc/cron.d/, the only post-exploitation task currently undetected by Wazuh).

Risk positions reflect analyst estimates based on attack chain progression and observed impact. This is not a formal CVSS scoring; CVSS does not apply directly to forensic findings in a post-compromise context where vulnerabilities are exploited rather than discovered.

MITRE ATT&CK Mapping

Each finding is mapped to one or more MITRE ATT&CK Enterprise techniques (v15) to align this assessment with industry-standard threat intelligence frameworks. This mapping enables downstream integration with SIEM detection rules, threat hunting playbooks, and red-team exercise planning.

Finding	Tactic	Technique ID	Technique Name
I1	Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning
I1	Credential Access	T1110.001	Brute Force: Password Guessing (failed diversion)
I2	Initial Access	T1078.003	Valid Accounts: Local Accounts
I2	Initial Access	T1133	External Remote Services
I2	Credential Access	T1552.004	Unsecured Credentials: Private Keys (harvested from INC-2026-001)
I2	Command and Control	T1572	Protocol Tunneling (Tor)
I3	Privilege Escalation	T1548.001	Abuse Elevation Control: Setuid and Setgid
I3	Discovery	T1057	Process Discovery (112 ps aux events)
I3	Discovery	T1083	File and Directory Discovery
I4	Credential Access	T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow
I5	Persistence	T1136.001	Create Account: Local Account (it_support)
I6	Credential Access	T1552.004	Unsecured Credentials: Private Keys (54 id_rsa searches)
I7	Persistence	T1053.003	Scheduled Task/Job: Cron

Tools and Standards

A. Tools Used During the Engagement

The following tools were used to investigate, validate, and document the findings in this report. All operations were conducted in a controlled SOC lab environment; no automated red-team toolset was deployed against the target.

Category	Tool	Purpose
Log forensics	grep / sed / awk	Authentication-event triage, field extraction, source-IP correlation
	sort / uniq -c	Frequency analysis of proctitle commands, source IPs, usernames
	xxd	Byte-level inspection of suspect log entries
SIEM analysis	Wazuh 4.x dashboard	Live alert validation, agent monitoring (tgt-blue11, id 041)
	Wazuh custom rules (100201-100205)	Existing 4 rules + 1 new rule proposed for cron persistence
Adversary emulation	MITRE Caldera	Phase 2 live attack simulation against tgt-blue11
	Caldera profile: lab2-linux-privesc	5.5-minute post-exploitation simulation (Tasks 4A-4D)
Decoding & analysis	base64 (CLI)	Decoding any payloads observed during the Caldera run
	jq	JSON parsing of Wazuh alert exports
Remote access	OpenSSH + Tailscale	Remote access to BeCode SOC workstation
Documentation	VS Code, Markdown	Note-taking, journal, report drafting

B. Standards and Frameworks Followed

This engagement was conducted in alignment with internationally recognized incident response and detection engineering frameworks to ensure methodological rigor, comparability with industry baselines, and consistency in finding classification and reporting.

Standard / Framework	Version	Application in This Report
NIST SP 800-61 Rev. 2	2012	Computer Security Incident Handling Guide - investigation methodology
NIST SP 800-86	2006	Integrating Forensic Techniques into Incident Response - log evidence handling
NIST SP 800-94	2007	Guide to Intrusion Detection and Prevention Systems - SIEM/HIDS context
SANS PICERL	-	Incident response phases (Preparation, Identification, Containment, Eradication, Recovery, Lessons)
MITRE ATT&CK Enterprise	v15	Technique mapping for findings and detection coverage analysis
MITRE Caldera	5.x	Adversary emulation framework for Phase 2 live detection validation
CVSS - Common Vulnerability Scoring System	v3.1	Severity scoring (Base Metrics) for each finding
CWE - Common Weakness Enumeration	v4.16	Root-cause classification of each finding
Wazuh rule syntax	4.x	Detection rule tuning proposals and new-rule authoring (100201-100205)
GTFOBins	-	SUID exploitation technique reference (find binary)

Glossary and Acronyms

The following table defines the technical acronyms and terms used throughout this report.

Acronym	Full Name	Description
API	Application Programming Interface	Endpoints exposed for programmatic interaction
auditd	Audit Daemon	Linux kernel-level audit subsystem capturing syscall events
auth.log	Authentication Log	Linux log file recording PAM, sudo, SSH, useradd events
beacon	Implant Callback	Periodic outbound contact from a compromised host to attacker C2
C2	Command and Control	Channel through which an attacker remotely controls compromised systems
Caldera	MITRE Caldera	Open-source adversary emulation framework by MITRE
CEST	Central European Summer Time	UTC+02:00, the local time zone for Brussels
chpasswd	Change Password (bulk)	Linux utility setting passwords from stdin; used by attacker post-useradd
CRON	Time-based Job Scheduler	Linux daemon executing scheduled tasks (often used for persistence)
CVE	Common Vulnerabilities and Exposures	Public catalogue of disclosed vulnerabilities
CVSS	Common Vulnerability Scoring System	Numerical severity scoring framework
CWE	Common Weakness Enumeration	Classification of software weaknesses
DFIR	Digital Forensics and Incident Response	Discipline combining evidence gathering and IR execution
euid	Effective User ID	The UID actually used by the kernel for permission checks (differs from uid when SUID set)
FIM	File Integrity Monitoring	Detection of unauthorized file changes
fail2ban	Fail-to-ban Daemon	Service banning source IPs after repeated authentication failures
GID	Group ID	Numeric identifier for a Linux group
GTF0Bins	Get The F*** Out Bins	Curated list of Unix binaries that can subvert restricted shells / escalate privileges
HIDS	Host-based Intrusion Detection System	Detection running on the monitored host (e.g. Wazuh agent)
IoC	Indicator of Compromise	Artifact pointing to malicious activity
JSON	JavaScript Object Notation	Lightweight data-interchange format
kill chain	Cyber Kill Chain	Sequence of stages an adversary follows from recon to objectives
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat intelligence framework
NIST	National Institute of Standards and Technology	U.S. agency publishing security standards
PAM	Pluggable Authentication Modules	Linux authentication framework
PICERL	Prep, Identification, Containment, Eradication, Recovery, Lessons	Security incident response process
PoC	Proof of Concept	Demonstration that a vulnerability is exploitable
PID	Process Identifier	Numeric ID assigned to each running Linux process
PPID	Parent Process Identifier	PID of the process that spawned the current process
proctitle	Process Title	The command-line representation of a process as captured by auditd
RAT	Remote Access Trojan	Malware providing persistent remote control over a compromised host
RCE	Remote Code Execution	Vulnerability allowing arbitrary code execution remotely
RFC1918	Private IPv4 Address Space	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16
SCP	Secure Copy Protocol	File transfer over SSH
SFTP	SSH File Transfer Protocol	Secure replacement for FTP
SHA256	Secure Hash Algorithm 256-bit	Cryptographic hash used in SSH key fingerprints
SIEM	Security Information and Event Management	Log aggregation and correlation platform

SOC	Security Operations Center	Team responsible for security monitoring and response
SSH	Secure Shell	Encrypted remote-administration protocol
SUID	Set User ID	Filesystem permission bit that runs an executable with owner privileges regardless of caller
sudo	Substitute User Do	Linux mechanism granting controlled privilege escalation
syscall	System Call	Interface between user-space process and kernel; logged by auditd
TCP	Transmission Control Protocol	Connection-oriented transport-layer protocol
Tor	The Onion Router	Anonymity network routing traffic through encrypted relays and exit nodes
TTPs	Tactics, Techniques and Procedures	Behaviour-level attacker characterisation
UID	User ID	Numeric identifier for a Linux user account
useradd	Add a New User	Linux utility creating local user accounts; used to install the backdoor
UTC	Coordinated Universal Time	Universal time reference (CEST = UTC+02:00)
Wazuh	-	Open-source SIEM and HIDS platform

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-002

Classification: Internal - Not for distribution

Analyst

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi